



# IT-Security

## Chapter 8: Data protection and data security

1. Data protection
2. Data Security





## What do we want to learn?



- ▶ Who or what does data protection protect?
- ▶ What is the significance of data protection for society?
- ▶ What is the significance of data protection for a company?
- ▶ What is the difference between data protection and data security?
- ▶ What measures are in place to support data protection and data security?



# Chapter 8.1: Data Protection

- Motivation
- Data protection law
- Principles and patterns



# Key arguments for data protection and privacy

- ▶ Everyone has a natural privacy
- ▶ The protection of your data is a human right!
- ▶ Private data has value, companies make a lot of money with your data!
- ▶ Your personality will be analyzed, and you will be manipulated with it!
- ▶ The state evaluates your data!
- ▶ Your data can fall into the hands of criminals!
- ▶ Privacy is essential for the functioning of an open, pluralistic democracy.

# Facebook Cambridge Analytica Scandal

- ▶ Cambridge Analytica is a political consulting company dedicated to creating psychographic profiles of voters
- ▶ For this purpose, data from various sources were collected and analyzed
- ▶ They developed a Facebook app for "scientific research"
- ▶ With consent, they got data from 270,000 profiles
- ▶ Data from at least 50 million other Facebook profiles were also analyzed (without direct consent...)

Source: New York Times, 17.03.2018



# The consequences of the Facebook Cambridge Analytica scandal for society

Trump becomes president 2016



Quelle: Wikimedia Commons 04.04.2019



# The Power of Facebook Predicting Personality Traits

*„Facebook knows you better than your partner...“*

## Computer-based personality judgments are more accurate than those made by humans

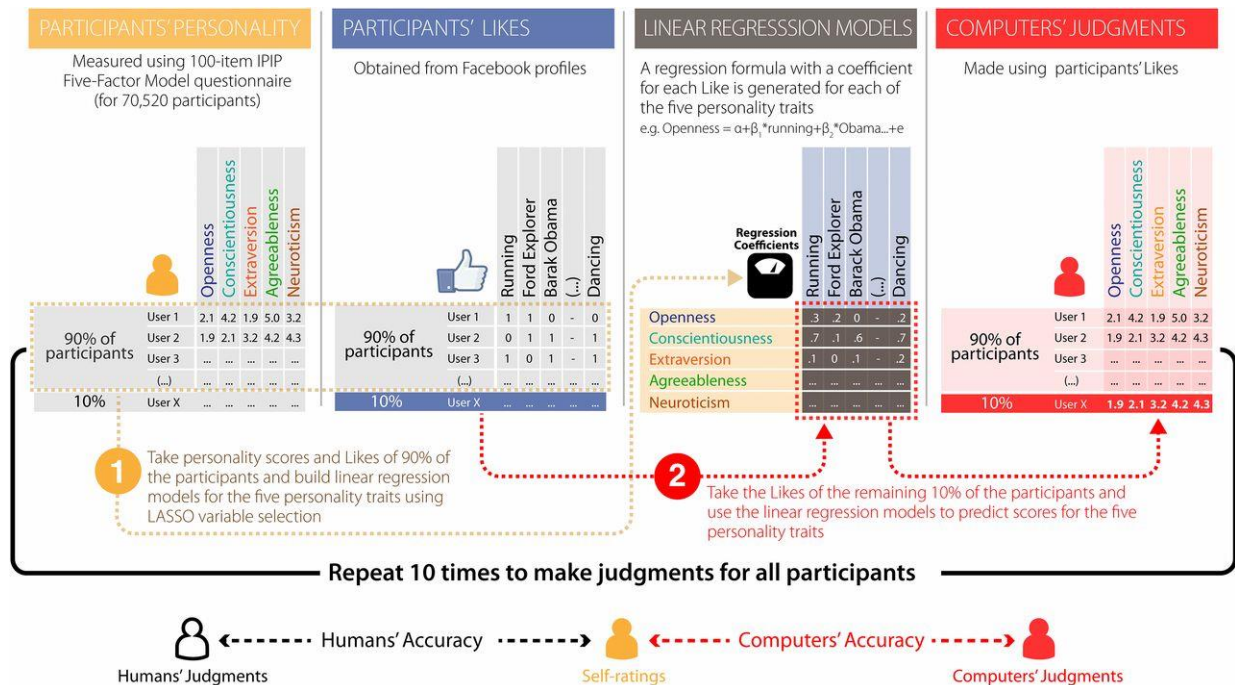
Wu Youyou<sup>1,2</sup>, Michal Kosinski<sup>1\*</sup>, and David Stillwell<sup>1\*</sup>

<sup>1</sup>Department of Psychology, University of Cambridge, Cambridge CB2 3EB, United Kingdom; and <sup>2</sup>Department of Computer Science, Stanford University, Stanford, CA 94305

Edited by David Funder, University of California, Riverside, CA, and accepted by the Editorial Board December 2, 2014 (received for review September 28, 2014)

Judging others' personalities is an essential skill in successful social living, as personality is a key driver behind people's interactions, behaviors, and emotions. Although accurate personality judgments stem from social-cognitive skills, developments in machine learning show that computer models can also make valid judgments. This study compares the accuracy of human and computer-based personality judgments, using a sample of 86,220 volunteers who completed a 100-item personality questionnaire. We show that (i) computer predictions based on a generic digital footprint (Facebook Likes) are more accurate ( $r = 0.58$ ) than those made by the participants' Facebook friends using a personality questionnaire ( $r = 0.49$ ); (ii) computer personality judgments have higher external validity when predicting life outcomes such as substance use, political attitudes, and physical health; for some outcomes, they even outperform the self-rated personality scores. Computers outperform humans in personality judgment presents

psychological traits (11). We used LASSO (Least Absolute Shrinkage and Selection Operator) linear regressions (16) with 10-fold cross-validations, so that judgments for each participant were made using models developed on a different subsample of participants and their Likes. Likes are used by Facebook users to express positive association with online and offline objects, such as products, activities, sports, musicians, books, restaurants, or websites. Given the variety of objects, subjects, brands, and people that can be liked and the number of Facebook users (>1.3 billion), Likes represent one of the most generic kinds of digital footprint. For instance, liking a brand or a product offers a proxy for consumer preferences and purchasing behavior; music-related Likes reveal music taste; and liked websites allow for approximating web browsing behavior. Consequently, Like-based models offer a good proxy of what could be achieved based on a wide range of other digital footprints such as





## But there are more privacy violations



*"Our mission: to organize the information of this world and make it generally accessible and usable." (2014)*

*Google stores search queries, location history, voice & audio activities, device information, AI requests, ....*



Accesses data from the address book, links your own information to account information from other networks, does profiling



- Amazon had systematically analyzed the click and purchase behavior of millions of users without consent (2021, fine 746 million €)
- Employee under pressure of continuous algorithmic surveillance (2024, fine 32 million €)
- Illegal access to Alexa speech recording for AI training (2019)



Analyzes customer data and recognizes "Rides of Glory" (2014), "Analytical game to improve the offer"





# Not only commercial companies infiltrate privacy

- ▶ States are also interested in our data



- ▶ NSA Scandal (2013)

- ▶ Edward Snowden publishes secret American documents, uncovering a major surveillance and espionage scandal.



- ▶ There is no universal data protection law
- ▶ There are different cultural and political philosophies
  - ▶ EU : Data privacy is a fundamental human right
  - ▶ USA: Data is commercial commodity
  - ▶ China: Data is national security asset



# Data protection

- ▶ Data protection regulates the processing of **personal data**
- ▶ The General Data Protection Regulation (**GDPR**) is a data protection law that came into effect on May 25, 2018 (**EU-GDPR** General Data Protection Rules)  
<https://gdpr.eu/> , <https://gdpr.eu/tag/gdpr/>
  - ▶ This means that there is a uniform level of data protection in the EU
  - ▶ the German version is the **DSGVO** (Datenschutz-Grundverordnung)  
<https://dsgvo-gesetz.de/>  
and **BDSG** (neu) (Bundesdatenschutzgesetz <https://dsgvo-gesetz.de/bdsg/>)
- ▶ There have been regulations before, but the data processors weren't very interested, as the consequences of penalties weren't terrible.
- ▶ High penalties since 2018 changed the significance



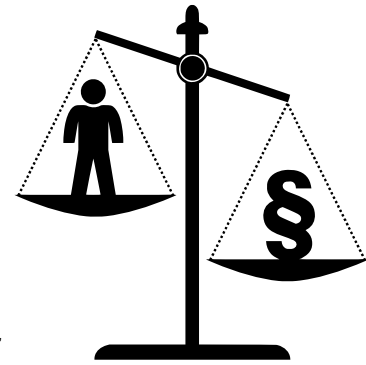
# What is personal data?



- ▶ **‘personal data’** means any information relating to an identified or identifiable **natural person** (**‘data subject’**);
  - ▶ Such as name, address, date of birth, gender, opinions, identification number, time tracking data, criminal record, hobby, license plate number, bank details, income level, financial circumstance, insurance data, customer profile data, location data, online identifier, IP-address, MAC-address, Cookies
  - ▶ or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;
- ▶ Art. 9 GDPR: Processing of special categories of personal data
  - ▶ Racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic and biometric data, health data, data concerning sex life or sexual orientation
  - ▶ Higher requirements for the justification of processing and data security apply here



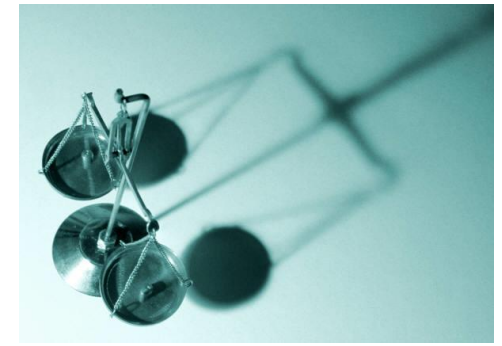
# When is processing of personal data legitimated?



- ▶ Permission by **consent** of the data subject
  - ▶ Consent must be „**freely given**“, specific, informed and unambiguous
  - ▶ Requests for consent must be “**clearly distinguishable** from the other matters”
  - ▶ Data subjects can **withdraw** previously given consent whenever they want
  - ▶ You need to keep **documentary** evidence of consent
  
- ▶ Permission by GDPR if the processing is necessary
  - ▶ for the performance of a **contract** to which the data subject is party
  
  - ▶ for **compliance with a legal obligation** to which the controller is subject
  - ▶ in order to protect the **vital interests** of the data subject or of another natural person
  - ▶ for the performance of a task carried out in the **public interest** or in the exercise of official authority vested in the controller
  
  - ▶ for the purposes of the **legitimate interests** pursued by the controller or by a third party,

# ▶ What are the rights of the data subjects?

- ▶ People have the right
  - ▶ to be informed
  - ▶ of access
  - ▶ to rectification
  - ▶ to erasure
  - ▶ to restrict processing
  - ▶ to data portability
  - ▶ to object



# What are the obligations of data processors?

- ▶ Keeping an electronic **record of processing**
  - ▶ must include significant information about data processing, including data categories, the group of data subjects, the purpose of the processing, the data recipients, time limits for erasure
- ▶ Management of the **rights of data subjects**
  - ▶ Acceptance and feedback process for inquiries or requests
  - ▶ Escalation procedure for complicated inquiries and complaints
- ▶ Handling **data breaches**
  - ▶ Obligation to notify supervisory authorities (**within 72 hours**) and client
  - ▶ Obligation to notify affected parties
  - ▶ Implementation of appropriate remedial measures
- ▶ Data Protection **Risk Management**
  - ▶ Risk assessment
  - ▶ Data Protection Impact Assessment



# What are the consequences of data breaches?



- ▶ Heavy fines for violations of the GDPR
  - ▶ Up to 20.000.000 €
  - ▶ Up to 4% of the revenue
  - ▶ plus data subjects have the right to seek compensation for damages



## Data Field Catalog and Data Privacy Classes

- ▶ As part of a **Data Protection Concept** for an IT application, a **Data Field Catalog** must be set up in which all personal data fields are listed together with their intended use

| Nr | Data field name | Group of persons | Intended use, purpose | Usage period and deletion | DPC |
|----|-----------------|------------------|-----------------------|---------------------------|-----|
|    |                 |                  |                       |                           |     |
|    |                 |                  |                       |                           |     |
|    |                 |                  |                       |                           |     |
|    |                 |                  |                       |                           |     |
|    |                 |                  |                       |                           |     |

- ▶ There are the following **Data Privacy Classes (DPC)**
  - ▶ DPC 0 public
  - ▶ DPC 1 internal (e.g. name, e-Mail, phone number)
  - ▶ DPC 2 confidential (e.g. birth date, nationality, identity card, contract details, invoices)
  - ▶ DPC 3 strictly confidential (e.g. usage of data of services, GPS positioning data, bank and account data, data according to Art. 9 GDPR)





# Anonymization and pseudonymization of data



- ▶ IT procedures often become less complicated when the personal reference of the data can be removed.

- ▶ **Anonymization**

- ▶ GDPR requires that all links between data and the data subject be irrevocably disconnected
- ▶ Anonymized data is not subject to data protection and can be stored and processed for any length of time

- ▶ **Pseudonymization**

- ▶ Personal data that can no longer be assigned to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organizational measures
- ▶ Pseudonymization allows big data analysis and AI



# The 7 principles of data protection in GDPR

- ▶ Lawfulness, fairness and transparency
- ▶ Purpose limitation
- ▶ Data minimization
- ▶ Accuracy
- ▶ Storage limitation
- ▶ Integrity and Confidentiality
- ▶ Accountability



# Privacy Design Strategies & Patterns: Data oriented

Quelle: ENISA, Privacy and Data Protection by Design – from policy to engineering, 2014,

Online unter <https://www.enisa.europa.eu/publications/privacy-and-data-protection-by-design> und <http://privacypatterns.org/>

**Minimise:** The amount of personal data that is collected should be restricted to the minimal amount possible.

Patterns:

- Anonymization
- Delete metadata
- Selective disclosure

**Hide:** Any personal data and their interrelationships should be hidden from plain view

Patterns:

- Encryption of data
- Unlink certain related events
- Pseudonyms

**Separate:** Personal data should be processed in a distributed fashion, in separate compartments whenever possible

Patterns:

- User data confinement pattern
- Personal data storage

**Aggregate:** Personal data should be processed at the highest level of aggregation and with the least possible detail in which it is (still) useful

Patterns:

- Aggregation over time
- Dynamic location granularity



# Privacy Design Strategien & Patterns: **Process oriented**

**Inform:** Data subjects should be adequately informed

Patterns:

- Privacy dashboard
- Privacy icons
- Data breach notification

**Control:** Data subjects should be provided agency over the processing of their data

Patterns:

- User centric identity management
- End-to-end encryption support

**Enforce:** A privacy policy should be in place and should be enforced

Patterns:

- Selective access control
- Sticky policies

**Demonstrate:** A data controller must be able to demonstrate compliance

Patterns:

- Privacy Management Systems



## Chapter 8.2: Data Security



## Differentiation between data protection and data security

- ▶ **Data protection** is the guarantee of the rights of a data subject with regard to the processing of his or her personal data
- ▶ **Data security** is the technical security, maintenance and availability of the data processing systems and the processed data
- ▶ Data security affects **all data** in the company
- ▶ Ensuring the data security of personal data is an important task in data protection
- ▶ For this purpose, **Technical Organizational Measures (TOM)** are required by law.



# TOM (Technical and organisational measures)



- ▶ **Art 28 part 3 DSGVO:** processing by a processor:
  - ▶ The processor shall be governed by a contract to the controller.  
(**DPA Data Processing Agreement**)
  - ▶ The processor must take all measures required under Article 32 of the GDPR (security of processing)
- ▶ The processor has to implement **TOM**
  - ▶ Physical access control
  - ▶ Logical access control (e.g. authentication, authorization)
  - ▶ User activity control (e.g. logging)
  - ▶ Availability control (e.g. redundancy)
  - ▶ Segregation control (data collected for different purposes are not mixed in their processing )
  - ▶ Job control and subcontracting (in accordance with the instructions of the controller)
  - ▶ Transfer and dissemination control (e.g. encryption in transit)
  - ▶ Review, assessment and evaluation



# Summary of Data Protection



- ▶ Data protection protects individuals when using their personal data
- ▶ Data protection is not possible without data security
- ▶ Data protection concerns personal data,  
data security concerns all data in the company
- ▶ Every company is legally obliged to fulfill data protection
- ▶ Software/AI Engineers have a social and legal obligation to take data protection seriously